

Introduction to Assignment and Framework

- The assignment 'IoT-CPS-Assignment-1' focuses on access control and defense methods for IoT and Cyber-Physical Systems, with a specific section dedicated to analyzing authentication patterns in practice, which accounts for 20 points of the assignment.
- The analysis framework for IoT and CPS environments identifies three critical dimensions: Vulnerability Type, Attack Vector, and Defense Principle, which are essential for understanding security flaws in authentication patterns and implementing proper defense mechanisms.
- The assignment examines three authentication patterns: Object Layer Authentication, Network Layer Authentication, and Middleware/Service Layer Authentication, each with its unique security flaws, such as constrained computational capability, phishing attacks, and virtual object trust questions.
- For the Object Layer Authentication, security flaws include vulnerability to entity replacement attacks, eavesdropping, and memory injection attacks, which can be mitigated using mutual authentication, lightweight cryptography, device fingerprinting, certificate-based authentication, hardware security, and Access Control Lists (ACLs).

Authentication Patterns and Their Flaws

- The Network Layer Authentication is vulnerable to phishing attacks, compromised credentials, heterogeneity issues, and weak configuration, which can be defended against using end-to-end encryption, network segmentation, multi-factor authentication, VPN tunneling, rate limiting, intrusion detection, and secure credential storage systems.
- The Middleware/Service Layer Authentication faces challenges related to virtual object trust questions and permission propagation, which require careful consideration of authentication mechanisms and permission management to ensure secure access to cloud resources.
- The assignment emphasizes the importance of implementing robust security measures, such as Elliptic-Curve Cryptography (ECC), Trusted Platform Modules (TPM), and secure credential storage systems, to protect IoT and CPS systems from various types of attacks and ensure the integrity of the entire system.

Defense Mechanisms for Authentication Layers

- The IoT-CPS-Assignment-1 document discusses various security concerns and defense patterns for IoT systems, including Cross-Layer Communication, Database Security, Service-to-Service, and Specific Middleware Vulnerabilities, which can be addressed through measures such as Cryptographic Key Pairing and Shadow/Replica Authentication.
- The document highlights the importance of proper authentication and authorization in IoT systems, including the use of Identity-Based Encryption (IBE), Topic-Based Access Control, and Policy-Based Access Control, to prevent unauthorized access and data breaches.
- The document also discusses security flaws in the IoT Application Layer, including Data Theft Risk, Access Control Attacks, and Malicious Code Injection, which can be mitigated through proper defense patterns such as API Authentication, Session Management, and Data Encryption.

Virtual Objects and Their Security Requirements

- To prevent Privilege Escalation in IoT/CPS, the document recommends implementing strict Role-Based Access Control (RBAC), privilege separation, and continuous permission verification, as well as object-level authorization verification and isolation between tenant data and control commands.
- The concept of Virtual Objects (VOs) is introduced as digital representations of physical IoT devices created in cloud/edge infrastructure, and the document emphasizes the need for a Virtual Object Authentication Framework to ensure secure communication and publish-subscribe security in IoT systems.
- The Virtual Object Security Requirements for IoT-CPS include bidirectional authentication between physical devices and virtual objects, secure synchronization of device state, access control for systems interacting with virtual objects, and confidentiality of data in virtual objects.
- To ensure proper implementation of security, three methods are employed: Cryptographic Key Pairing, Certificate-Based Authentication, and Shadow Authentication Protocol, which establish a secure binding between physical devices and virtual objects, verify device identities, and prevent unauthorized device state manipulation.

Access Control Mechanisms

- The Publish-Subscribe (MQTT) security in IoT utilizes Topic-Based Access Control, where topics are defined as channels for publishers to send data and subscribers to

receive data, and access control requirements include publisher authorization, subscriber authorization, and data forwarding control.

- Access Control Lists (ACL) and Capability-Based Models are used to enforce access control, where ACLs define permissions per topic and capability lists define permissions per virtual object, and proper access control enforcement involves checking sender capabilities, receiver ACL permissions, and validating conditions.
- Attribute-Based Access Control (ABAC) is used for fine-grained IoT authorization, utilizing attributes such as device attributes (type, location, health/status, manufacturer, firmware version, and trust level), topic/resource attributes (sensitivity level, geographic scope, and data classification), to make access decisions and ensure secure interactions between devices and virtual objects.

Three-Layer IoT Security Model and Cloud Security

- The document also presents a three-layer IoT security model, consisting of the Object Layer, Network/Middleware Layer, and Application/Cloud Layer, each with its own entities, constraints, threats, and controls, such as lightweight cryptography, network segmentation, and role-based access control.
- Additionally, the document discusses cloud-enabled IoT security principles, including single cloud architecture and multi-cloud and edge/fog architecture, and highlights the security advantages and challenges of each approach, such as centralized authentication and authorization, single point of failure, and vendor lock-in.

Case Study: Mirai Botnet Attack

- The document also provides a case study of the Mirai botnet attack on IoT devices in 2016, which was caused by authentication failures, including the use of default credentials, weak brute-force protection, unencrypted authentication, and lack of mutual authentication, and it emphasizes the importance of proper security measures, such as trust establishment, cross-cloud access control, data isolation, authentication bridging, and audit logging.
- The proper defense pattern against such attacks involves using a Security Credential Management System (SCMS) or Public Key Infrastructure (PKI)-based trust, implementing trust-based ABAC for inter-cloud communication, keeping sensitive data in authorized clouds only, creating authenticated channels between cloud trust domains, and maintaining centralized logging of all cross-cloud access.

Security Lessons and Mitigation Strategies

- The IoT-CPS-Assignment-1 document discusses the security concerns and mitigation strategies for Internet of Things (IoT) and Cyber-Physical Systems (CPS), highlighting the importance of prioritizing security over functionality in the design of IoT devices.
- The document outlines various security lessons, including the need to force credential changes on first boot, implement rate limiting and exponential backoff, and always encrypt authentication traffic, as well as the importance of mutual authentication between devices and servers using certificates.
- To mitigate modern IoT security threats, the document recommends implementing secure boot mechanisms, trusted execution environments, certificate pinning, firmware validation, and regular security updates to patch known authentication vulnerabilities.

Vulnerability Assessment and Defense-in-Depth

- The document also presents a vulnerability assessment framework for IoT/CPS, classifying vulnerabilities into cyber, physical, and cyber-physical categories, and outlining a threat identification process that involves asset inventory, threat analysis, vulnerability scanning, risk scoring, and mitigation planning.
- A defense-in-depth approach is proposed, consisting of a layered security architecture with five layers: identity and authentication, authorization and access control, communication security, monitoring and detection, and incident response, each with its own set of security mechanisms and protocols.

Blockchain for Trust Management

- The document also explores the use of blockchain technology for trust management in CPS, highlighting its potential to provide decentralized trust, immutable records, smart contracts, and distributed verification, and outlining several IoT-specific blockchain applications, including device identity registries, capability delegation, trust scoring, and more.
- The blockchain-based approach is presented as a solution to traditional authentication challenges in CPS, such as the lack of a centralized authority, difficulty in establishing trust between unknown entities, and legacy systems lacking modern authentication mechanisms.
- Overall, the document provides a comprehensive overview of the security challenges and mitigation strategies for IoT and CPS, emphasizing the need for a

multi-layered approach to security and the potential benefits of using blockchain technology for trust management.

Security Checklists and Key Principles

- The IoT-CPS-Assignment-1 document outlines a comprehensive approach to securing IoT and Cyber-Physical Systems, emphasizing the importance of authentication and authorization strategies that address the unique constraints and threats of these environments.
- The document provides three security checklists, including the IoT Device Security Checklist, the Cloud/Edge Gateway Security Checklist, and the IoT Application Security Checklist, which cover various aspects of security such as device firmware, communication encryption, and access control.
- The IoT Device Security Checklist requires that all devices ship with unique cryptographic keys, have cryptographically signed and verified firmware, and use mutual authentication with certificates, as well as implementing rate limiting, secure key storage, and automatic security updates.
- The Cloud/Edge Gateway Security Checklist mandates multi-factor authentication for gateway administration, X.509 certificate-based device authentication, and role-based access control for device commands, in addition to encrypted database storage and intrusion detection system monitoring.
- The IoT Application Security Checklist specifies the use of API authentication with OAuth 2.0, session tokens with expiration, input validation, and role-based access control enforcement, as well as encrypting sensitive IoT data at rest and implementing application-level audit logging.
- The document concludes by highlighting six key principles for securing IoT and Cyber-Physical Systems, including the use of lightweight cryptography, mutual authentication, defense-in-depth, decentralized trust, continuous monitoring, and user control, emphasizing that organizations must treat authentication and authorization as foundational security controls.